



ÉCOLE POLYTECHNIQUE DE SOUSSE

TP5

Analyse de trafic réseau avec Wireshark

Élève :
Hichri SAFA

Enseignant :
Gontara SALAH

- Année Universitaire 2025-2026

Table des matières

1	TP4	4
1.1	Introduction générale	4
1.2	lotsofweb.pcapng — Trafic Web Normal	5
1.3	Example-1-2021-01-06-Emotet-infection — Infection Emotet	9
1.4	Example-2-2021-01-05-Emotet-with-spambot — Activité Spambot	13
1.5	Example-5-2020-08-18-Emotet-with-Qakbot — Double infection	15
1.6	2021-10-14-Stolen-Images-Evidence-BazarLoader — Téléchargement payload	17
1.7	2021-10-20-TA551-pushes-Sliver — C2 Sliver	20
1.8	Conclusion générale	21

Table des figures

1.1	Capture file Properties	5
1.2	Protocol Hierarchy	6
1.3	Endpoints	7
1.4	Filtre http.request	7
1.5	dns	8
1.6	Protocol Hierarchy	9
1.7	endpoints	10
1.8	http.request.method == "POST"	10
1.9	TLS	11
1.10	Follow HTTP stream	12
1.11	Protocol Hierarchy	13
1.12	filtre stmp	13
1.13	Conversations	14
1.14	Protocol Hierarchy	15
1.15	filtre HTTP request	16
1.16	Filtre handshake type	16
1.17	Protocol Hierarchy	17
1.18	HTTP request	17
1.19	export des objets HTTP	18
1.20	Follow http stream	19
1.21	Protocol Hierarchy	20
1.22	handshake	20
1.23	filtre tcp.dstport != 80 && tcp.dstport != 443	21
1.24	Endpoints	21

Liste des tableaux

Chapitre 1

TP4

1.1 Introduction générale

Ce laboratoire porte sur l'analyse comparative de trafic réseau à l'aide de **Wireshark**, dans le cadre d'une démarche de forensique réseau. L'analyse de trafic réseau constitue une composante essentielle de toute investigation numérique, permettant de reconstituer les communications d'un système, d'identifier des comportements malveillants, et de produire des indicateurs de compromission (IOC) exploitables.

Ce TP porte sur l'analyse de huit captures réseau couvrant deux catégories de trafic distinctes :

- **Trafic normal** : une capture de navigation web classique servant de référence comparative (`lotsofweb.pcapng`).
- **Trafic malveillant** : sept captures documentant des infections réelles par des familles de malwares majeures : Emotet, Trickbot, Qakbot, BazarLoader et Sliver, couvrant des scénarios variés incluant des infections C2, des activités spambot, des téléchargements de payloads et des mouvements latéraux.

L'objectif est de produire une synthèse comparative argumentée, en exploitant les fonctionnalités avancées de Wireshark : hiérarchie des protocoles, endpoints, conversations, filtres d'affichage, suivi de flux et export d'objets HTTP. Toutes les analyses ont été menées uniquement avec Wireshark, conformément aux consignes du TP.

1.2 lotsofweb.pcapng — Trafic Web Normal

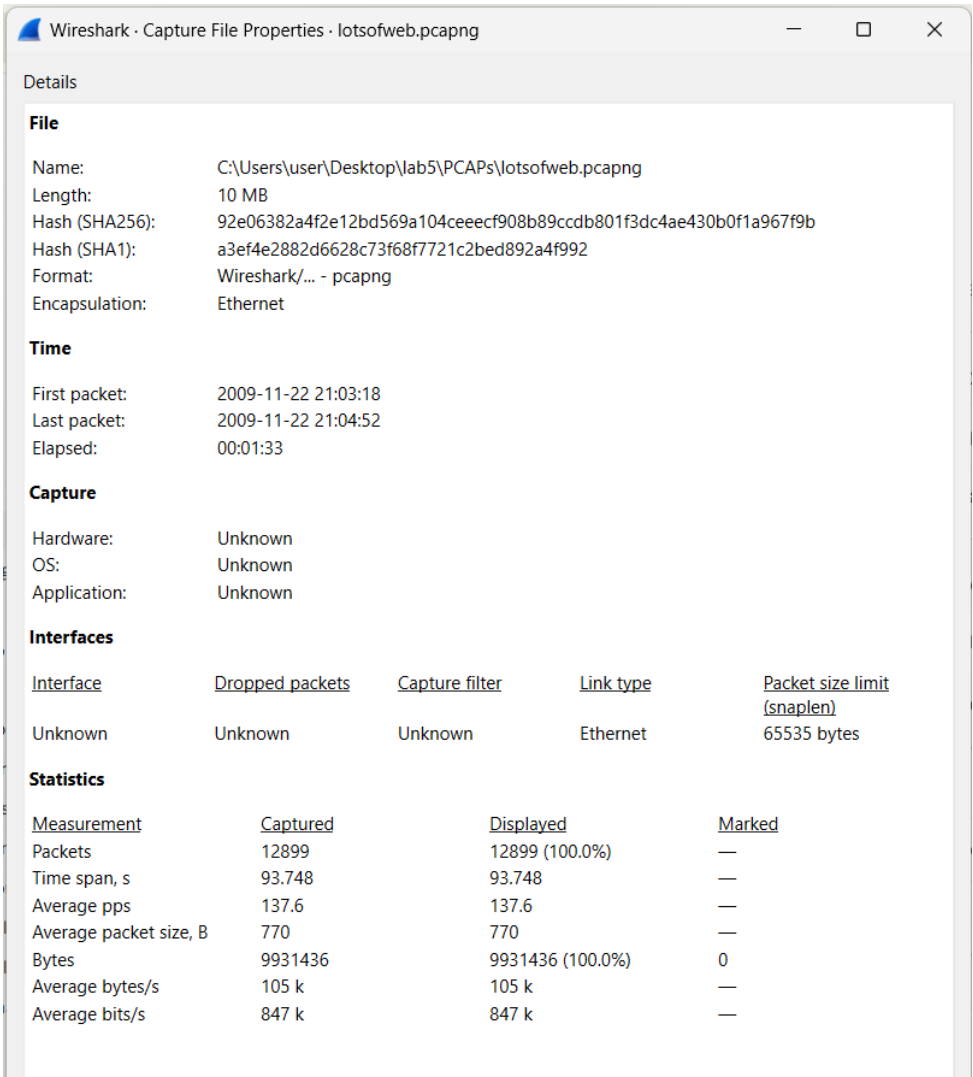


FIGURE 1.1 – Capture file Properties

La capture `lotsofweb.pcapng` représente une session de navigation web classique d’une durée de 1 minute et 33 secondes, contenant 12 899 paquets pour un volume total de 10 Mo.

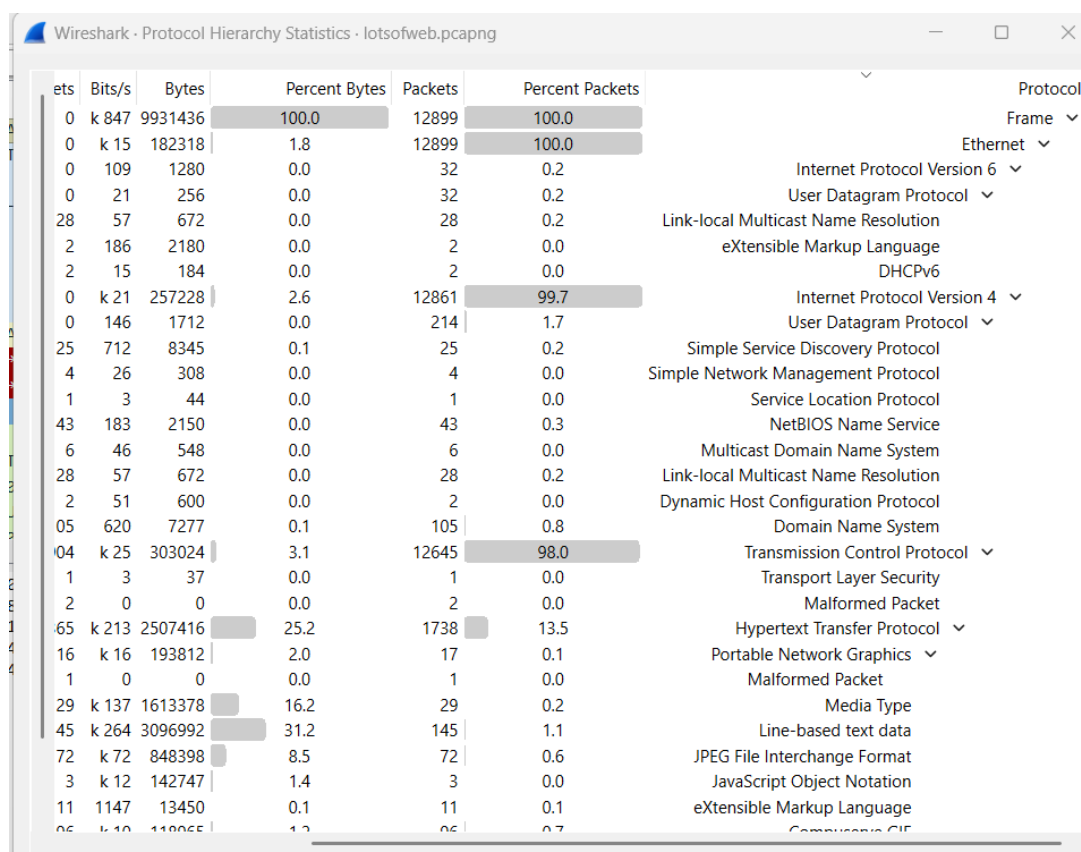
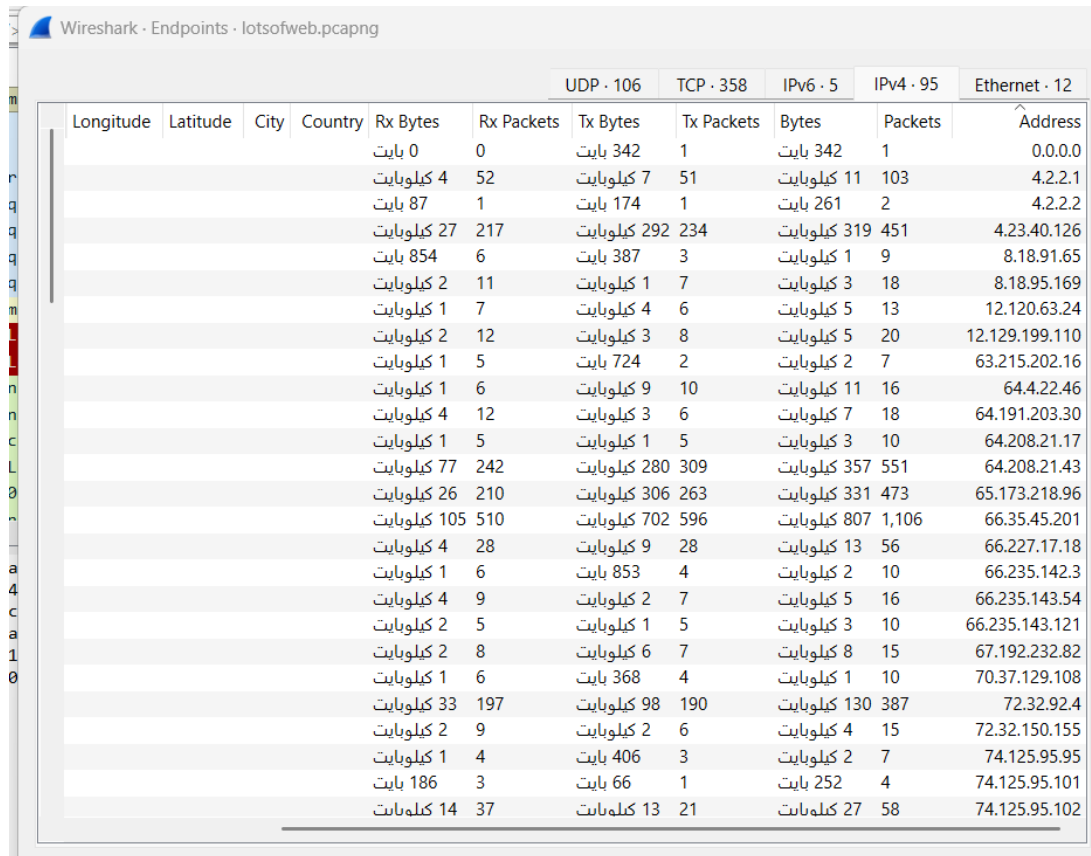


FIGURE 1.2 – Protocol Hierarchy

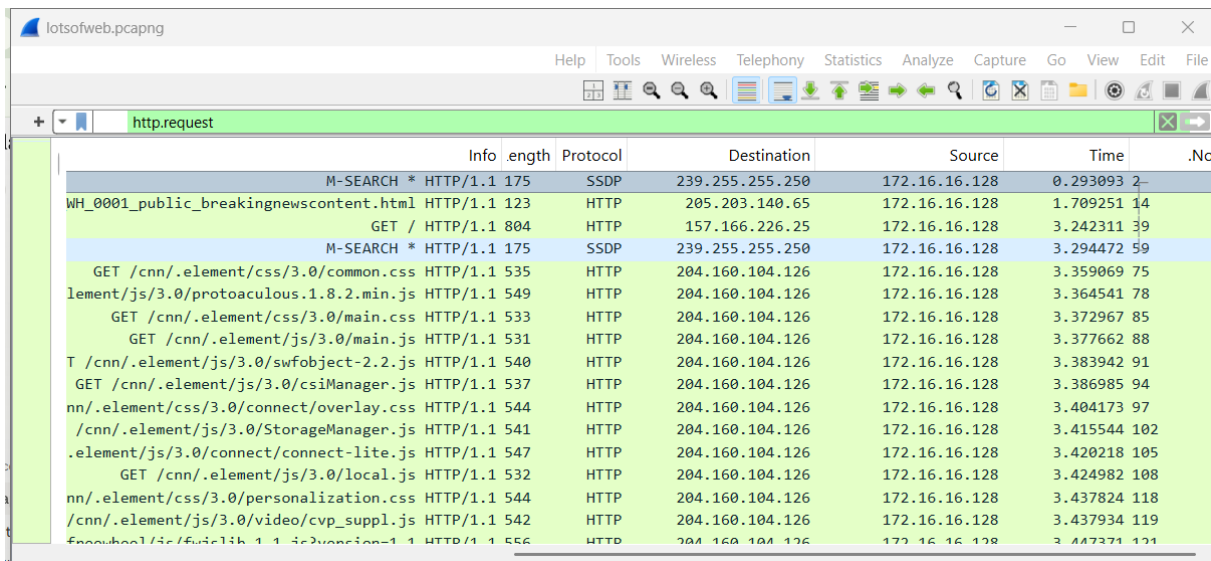
Protocoles dominants : L'analyse via *Protocol Hierarchy* révèle une dominance du protocole TCP (98% des paquets), avec HTTP comme protocole applicatif principal (13,5% des paquets, 1738 paquets). Le DNS est présent de manière marginale (0,8%). L'absence totale de TLS (filtre `tls.handshake.type == 1` retourne zéro résultat) indique un trafic entièrement non chiffré, caractéristique d'une capture ancienne (2009).



Longitude	Latitude	City	Country	Rx Bytes	Rx Packets	Tx Bytes	Tx Packets	Bytes	Packets	Address
0				0	0	342	1	342	1	0.0.0.0
4				52	52	7	51	11	103	4.2.2.1
87				1	1	174	1	261	2	4.2.2.2
27				217	217	292	234	319	451	4.23.40.126
854				6	6	387	3	1	9	8.18.91.65
2				11	11	1	7	3	18	8.18.95.169
1				7	7	4	6	5	13	12.120.63.24
2				12	12	3	8	5	20	12.129.199.110
1				5	5	724	2	2	7	63.215.202.16
1				6	6	9	10	11	16	64.4.22.46
4				12	12	3	6	7	18	64.191.203.30
1				5	5	1	5	3	10	64.208.21.17
77				242	242	280	309	357	551	64.208.21.43
26				210	210	306	263	331	473	65.173.218.96
105				510	510	702	596	807	1,106	66.35.45.201
4				28	28	9	28	13	56	66.227.17.18
1				6	6	853	4	2	10	66.235.142.3
4				9	9	2	7	5	16	66.235.143.54
2				5	5	1	5	3	10	66.235.143.121
2				8	8	6	7	8	15	67.192.232.82
1				6	6	368	4	1	10	70.37.129.108
33				197	197	98	190	130	387	72.32.92.4
2				9	9	2	6	4	15	72.32.150.155
1				4	4	406	3	2	7	74.125.95.95
186				3	3	66	1	252	4	74.125.95.101
14				37	37	13	21	27	58	74.125.95.102

FIGURE 1.3 – Endpoints

Hôtes et conversations : On dénombre 95 endpoints IPv4 distincts. Toutes les conversations TCP sont établies sur le port 80, confirmant l'utilisation exclusive de HTTP. L'hôte interne 172.16.16.128 communique avec de nombreux serveurs externes légitimes.

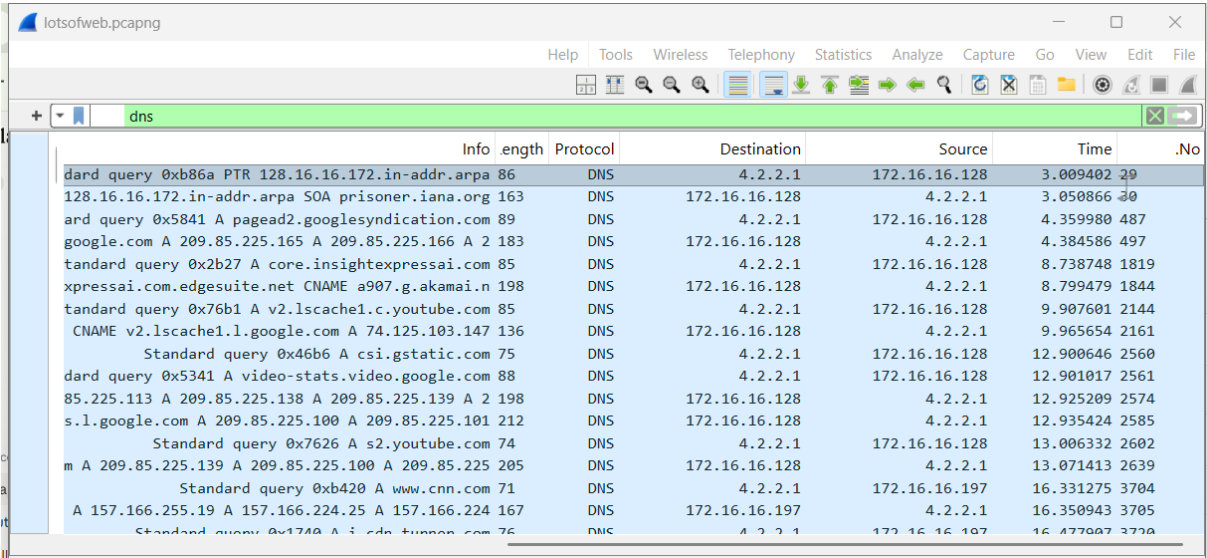


Info	length	Protocol	Destination	Source	Time	No.
M-SEARCH * HTTP/1.1	175	SSDP	239.255.255.250	172.16.16.128	0.293093	2
WH_0001_public_breakingnewscontent.html HTTP/1.1	123	HTTP	205.203.140.65	172.16.16.128	1.709251	14
GET / HTTP/1.1	804	HTTP	157.166.226.25	172.16.16.128	3.242311	39
M-SEARCH * HTTP/1.1	175	SSDP	239.255.255.250	172.16.16.128	3.294472	59
GET /cnn/.element/css/3.0/common.css HTTP/1.1	535	HTTP	204.160.104.126	172.16.16.128	3.359069	75
element/js/3.0/protoaculous.1.8.2.min.js HTTP/1.1	549	HTTP	204.160.104.126	172.16.16.128	3.364541	78
GET /cnn/.element/css/3.0/main.css HTTP/1.1	533	HTTP	204.160.104.126	172.16.16.128	3.372967	85
GET /cnn/.element/js/3.0/main.js HTTP/1.1	531	HTTP	204.160.104.126	172.16.16.128	3.377662	88
T /cnn/.element/js/3.0/swfobject-2.2.js HTTP/1.1	540	HTTP	204.160.104.126	172.16.16.128	3.383942	91
GET /cnn/.element/js/3.0/csiManager.js HTTP/1.1	537	HTTP	204.160.104.126	172.16.16.128	3.386985	94
nn/.element/css/3.0/connect/overlay.css HTTP/1.1	544	HTTP	204.160.104.126	172.16.16.128	3.404173	97
/cnn/.element/js/3.0/StorageManager.js HTTP/1.1	541	HTTP	204.160.104.126	172.16.16.128	3.415544	102
.element/js/3.0/connect/connect-lite.js HTTP/1.1	547	HTTP	204.160.104.126	172.16.16.128	3.420218	105
GET /cnn/.element/js/3.0/local.js HTTP/1.1	532	HTTP	204.160.104.126	172.16.16.128	3.424982	108
nn/.element/css/3.0/personalization.css HTTP/1.1	544	HTTP	204.160.104.126	172.16.16.128	3.437824	118
/cnn/.element/js/3.0/video/cvp_suppl.js HTTP/1.1	542	HTTP	204.160.104.126	172.16.16.128	3.437934	119
nn/.element/js/3.0/video/cvp_suppl.js HTTP/1.1	542	HTTP	204.160.104.126	172.16.16.128	3.447371	121

FIGURE 1.4 – Filtre http.request

Contenu du trafic : Le filtre `http.request` révèle des requêtes GET vers des domaines reconnus : CNN, Google, YouTube, et leurs CDN associés. Les requêtes DNS

confirment la résolution de noms de domaine légitimes (google.com, youtube.com, cnn.com).



No	Time	Source	Destination	Protocol	Length	Info
1	3.009402	172.16.16.128	4.2.2.1	DNS	86	Standard query 0xb86a PTR 128.16.16.172.in-addr.arpa
2	3.050866	4.2.2.1	172.16.16.128	DNS	163	128.16.16.172.in-addr.arpa SOA prisoner.iana.org
3	4.359980	172.16.16.128	4.2.2.1	DNS	89	Standard query 0x5841 A pagead2.googlesyndication.com
4	4.384586	4.2.2.1	172.16.16.128	DNS	183	google.com A 209.85.225.165 A 209.85.225.166 A 2
5	8.738748	172.16.16.128	4.2.2.1	DNS	85	Standard query 0x2b27 A core.insightexpressai.com
6	8.799479	4.2.2.1	172.16.16.128	DNS	198	xpressai.com.edgesuite.net CNAME a907.g.akamai.net
7	9.907601	172.16.16.128	4.2.2.1	DNS	85	Standard query 0x76b1 A v2.lscache1.c.youtube.com
8	9.965654	4.2.2.1	172.16.16.128	DNS	136	CNAME v2.lscache1.l.google.com A 74.125.103.147
9	12.900646	172.16.16.128	4.2.2.1	DNS	75	Standard query 0x46b6 A csi.gstatic.com
10	12.901017	172.16.16.128	4.2.2.1	DNS	88	Standard query 0x5341 A video-stats.video.google.com
11	12.925209	4.2.2.1	172.16.16.128	DNS	198	85.225.113 A 209.85.225.138 A 209.85.225.139 A 2
12	12.935424	4.2.2.1	172.16.16.128	DNS	212	s.l.google.com A 209.85.225.100 A 209.85.225.101
13	13.006332	172.16.16.128	4.2.2.1	DNS	74	Standard query 0x7626 A s2.youtube.com
14	13.071413	4.2.2.1	172.16.16.128	DNS	205	m A 209.85.225.139 A 209.85.225.100 A 209.85.225
15	16.331275	172.16.16.197	4.2.2.1	DNS	71	Standard query 0xb420 A www.cnn.com
16	16.350943	4.2.2.1	172.16.16.197	DNS	167	A 157.166.255.19 A 157.166.224.25 A 157.166.224
17	16.477907	172.16.16.197	4.2.2.1	DNS	76	Standard query 0x1740 A i.sdn.turner.com

FIGURE 1.5 – dns

Verdict : Ce trafic est classifié comme normal. Il constitue la référence de trafic web sain dans notre analyse comparative.

1.3 Example-1-2021-01-06-Emotet-infection — Infection Emotet

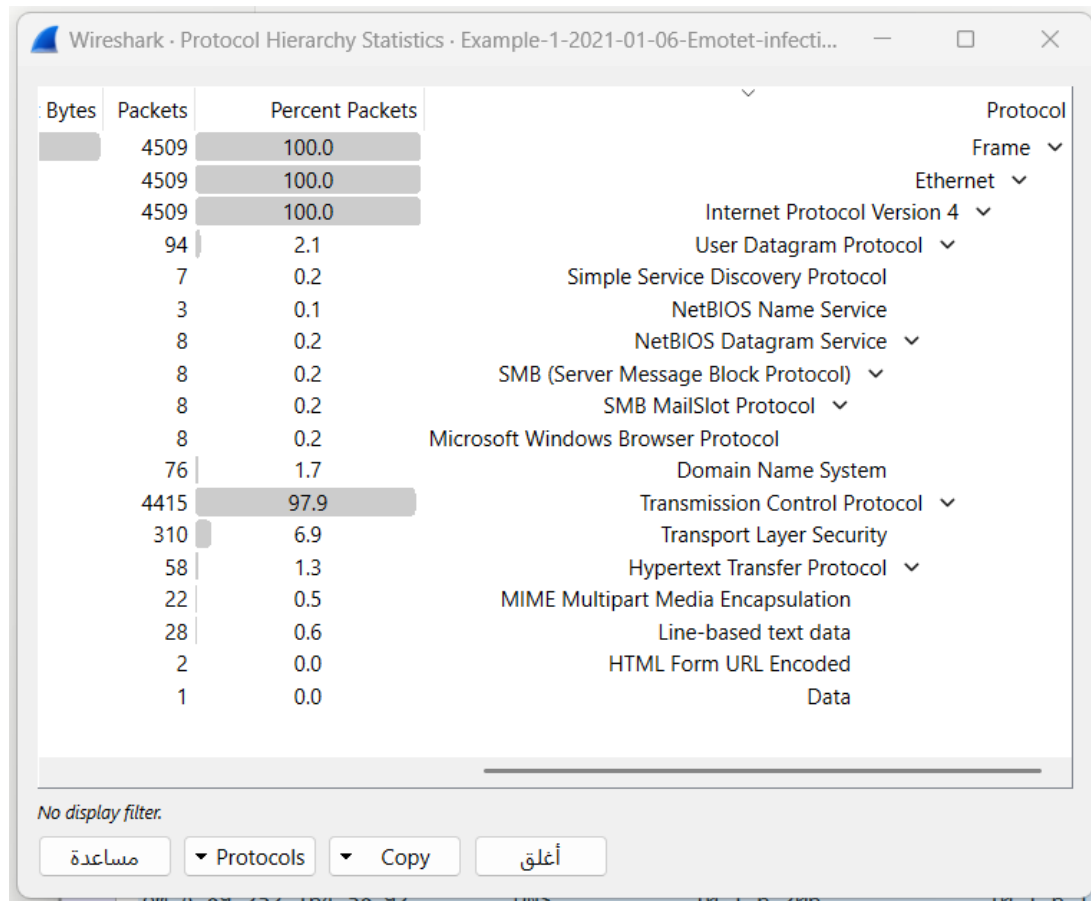
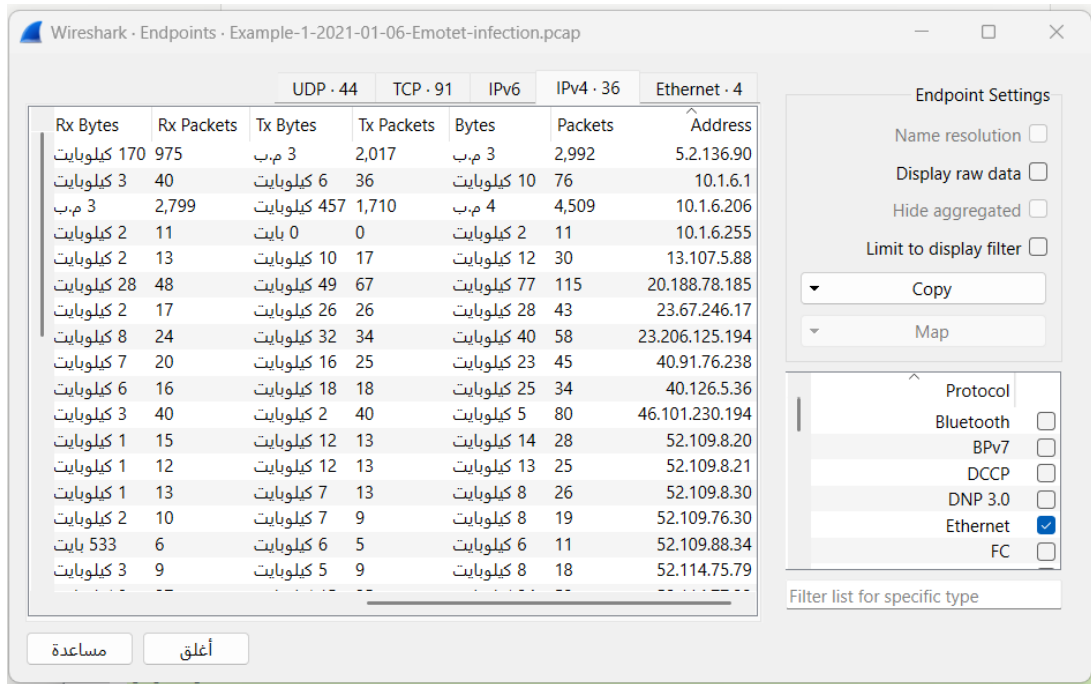


FIGURE 1.6 – Protocol Hierarchy

Protocoles dominants : L'analyse via *Protocol Hierarchy* révèle une dominance de TCP (97,9%), avec la présence de TLS (6,9%) et HTTP (1,3%). La présence simultanée de HTTP non chiffré et de TLS indique deux canaux de communication distincts utilisés par le malware.



Wireshark · Endpoints · Example-1-2021-01-06-Emotet-infection.pcap

UDP · 44 TCP · 91 IPv6 IPv4 · 36 Ethernet · 4

Rx Bytes	Rx Packets	Tx Bytes	Tx Packets	Bytes	Packets	Address
170 كيلوبايت	975	3 م.ب	2,017	3 م.ب	2,992	5.2.136.90
3 كيلوبايت	40	6 كيلوبايت	36	10 كيلوبايت	76	10.1.6.1
3 م.ب	2,799	457 كيلوبايت	1,710	4 م.ب	4,509	10.1.6.206
2 كيلوبايت	11	0 بايت	0	2 كيلوبايت	11	10.1.6.255
2 كيلوبايت	13	10 كيلوبايت	17	12 كيلوبايت	30	13.107.5.88
28 كيلوبايت	48	49 كيلوبايت	67	77 كيلوبايت	115	20.188.78.185
2 كيلوبايت	17	26 كيلوبايت	26	28 كيلوبايت	43	23.67.246.17
8 كيلوبايت	24	32 كيلوبايت	34	40 كيلوبايت	58	23.206.125.194
7 كيلوبايت	20	16 كيلوبايت	25	23 كيلوبايت	45	40.91.76.238
6 كيلوبايت	16	18 كيلوبايت	18	25 كيلوبايت	34	40.126.5.36
3 كيلوبايت	40	2 كيلوبايت	40	5 كيلوبايت	80	46.101.230.194
1 كيلوبايت	15	12 كيلوبايت	13	14 كيلوبايت	28	52.109.8.20
1 كيلوبايت	12	12 كيلوبايت	13	13 كيلوبايت	25	52.109.8.21
1 كيلوبايت	13	7 كيلوبايت	13	8 كيلوبايت	26	52.109.8.30
2 كيلوبايت	10	7 كيلوبايت	9	8 كيلوبايت	19	52.109.76.30
533 بايت	6	6 كيلوبايت	5	6 كيلوبايت	11	52.109.88.34
3 كيلوبايت	9	5 كيلوبايت	9	8 كيلوبايت	18	52.114.75.79

Endpoint Settings

Name resolution ☐

Display raw data ☐

Hide aggregated ☐

Limit to display filter ☐

Copy

Map

Protocol

Bluetooth ☐

BPv7 ☐

DCCP ☐

DNP 3.0 ☐

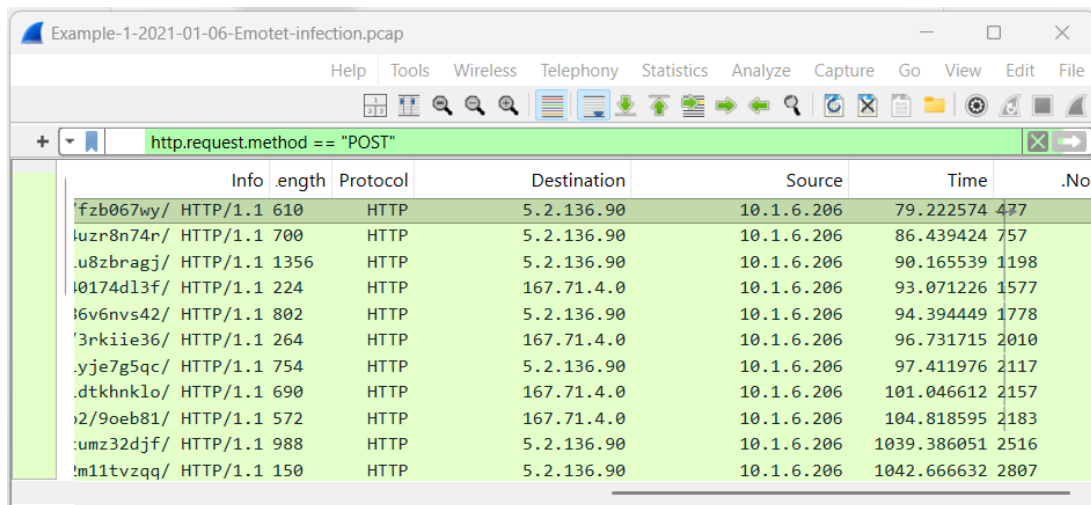
Ethernet ☒

FC ☐

Filter list for specific type

مساعدة أعلق

FIGURE 1.7 – endpoints



Example-1-2021-01-06-Emotet-infection.pcap

Help Tools Wireless Telephony Statistics Analyze Capture Go View Edit File

http.request.method == "POST"

Info	length	Protocol	Destination	Source	Time	.No
fzb067wy/ HTTP/1.1	610	HTTP	5.2.136.90	10.1.6.206	79.222574	477
luzr8n74r/ HTTP/1.1	700	HTTP	5.2.136.90	10.1.6.206	86.439424	757
u8zbragj/ HTTP/1.1	1356	HTTP	5.2.136.90	10.1.6.206	90.165539	1198
0174d13f/ HTTP/1.1	224	HTTP	167.71.4.0	10.1.6.206	93.071226	1577
6v6nvs42/ HTTP/1.1	802	HTTP	5.2.136.90	10.1.6.206	94.394449	1778
3rkiie36/ HTTP/1.1	264	HTTP	167.71.4.0	10.1.6.206	96.731715	2010
yje7g5qc/ HTTP/1.1	754	HTTP	5.2.136.90	10.1.6.206	97.411976	2117
dtkhnklo/ HTTP/1.1	690	HTTP	167.71.4.0	10.1.6.206	101.046612	2157
2/9oeb81/ HTTP/1.1	572	HTTP	167.71.4.0	10.1.6.206	104.818595	2183
umz32djf/ HTTP/1.1	988	HTTP	5.2.136.90	10.1.6.206	1039.386051	2516
m11tvzqq/ HTTP/1.1	150	HTTP	5.2.136.90	10.1.6.206	1042.666632	2807

FIGURE 1.8 – http.request.method == "POST"

Indicateurs C2 — HTTP POST : Le filtre `http.request.method == "POST"` révèle de multiples requêtes POST vers les serveurs C2, avec des URIs pseudo-aléatoires caractéristiques d'Emotet (ex : `/7u0e9j2avwlvnuynyo/szcm27k/fzb067wy/`). L'analyse du flux HTTP via *Follow HTTP Stream* confirme l'envoi de données binaires encodées (Content-Type: `application/octet-stream`) — signature typique de l'exfiltration de credentials et system info par Emotet.

	Info	length	Protocol	Destination	Source	Time	.No
	lata.microsoft.com)	242	TLSv1.2	52.114.132.91	10.1.6.206	4.224875	52
	late.microsoft.com)	265	TLSv1.2	20.188.78.185	10.1.6.206	29.965203	85
	lata.microsoft.com)	268	TLSv1.2	52.114.77.33	10.1.6.206	30.517524	151
	r.mp.microsoft.com)	270	TLSv1.2	111.221.29.40	10.1.6.206	32.118588	221
	lata.microsoft.com)	268	TLSv1.2	52.114.77.33	10.1.6.206	32.583427	227
	lata.microsoft.com)	268	TLSv1.2	52.114.77.33	10.1.6.206	35.573025	286
	officeapps.live.com)	251	TLSv1.2	52.109.8.21	10.1.6.206	87.170104	777
	lata.microsoft.com)	274	TLSv1.2	52.114.132.91	10.1.6.206	92.533461	1456
	officeapps.live.com)	251	TLSv1.2	52.109.8.21	10.1.6.206	97.840120	2125
	lata.microsoft.com)	268	TLSv1.2	52.114.88.21	10.1.6.206	326.467835	2219
	INI=login.live.com)	253	TLSv1.2	40.126.5.36	10.1.6.206	351.582701	2243

FIGURE 1.9 – TLS

TLS : Les handshakes TLS sont dirigés vers des adresses Microsoft légitimes, mais aussi vers des IPs suspectes non résolues, suggérant l'utilisation de TLS pour masquer une partie des communications C2.

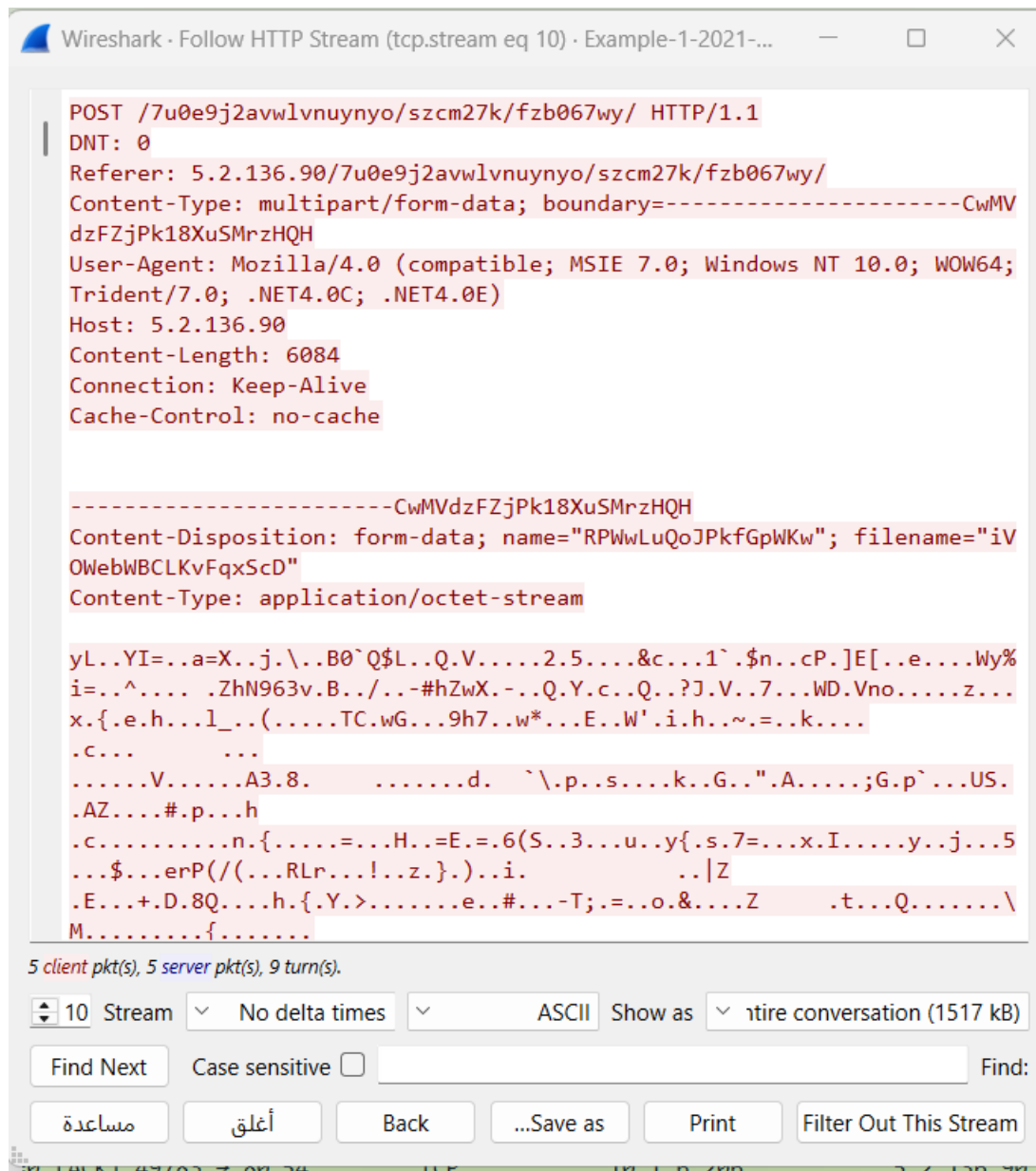


FIGURE 1.10 – Follow HTTP stream

Verdict : Trafic **malveillant**. Infection Emotet confirmée par la présence de POSTs C2 avec URIs aléatoires, exfiltration de données binaires via HTTP, et communications TLS vers serveurs non identifiés.

1.4 Example-2-2021-01-05-Emotet-with-spambot — Activité Spambot

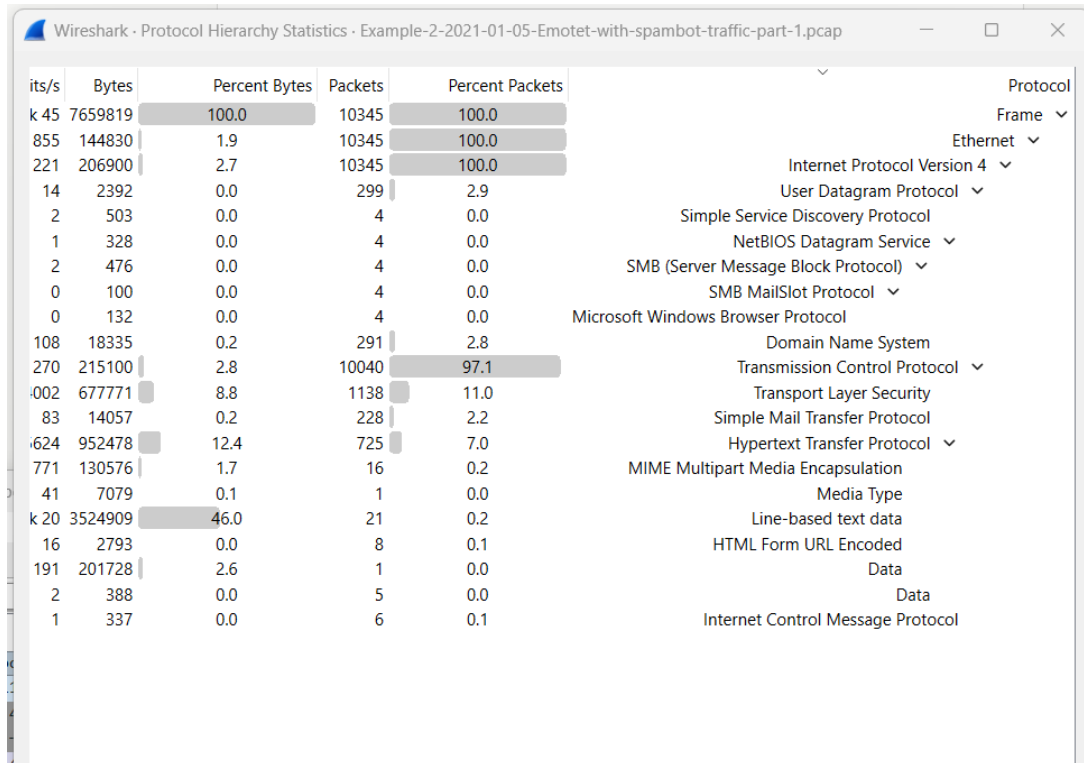


FIGURE 1.11 – Protocol Hierarchy

Protocoles dominants : L'analyse via *Protocol Hierarchy* révèle la présence significative de SMTP (2,2% – 228 paquets), de TLS (11%) et HTTP (7%). La combinaison SMTP + TLS est caractéristique d'une activité d'envoi d'emails via des serveurs légitimes détournés.

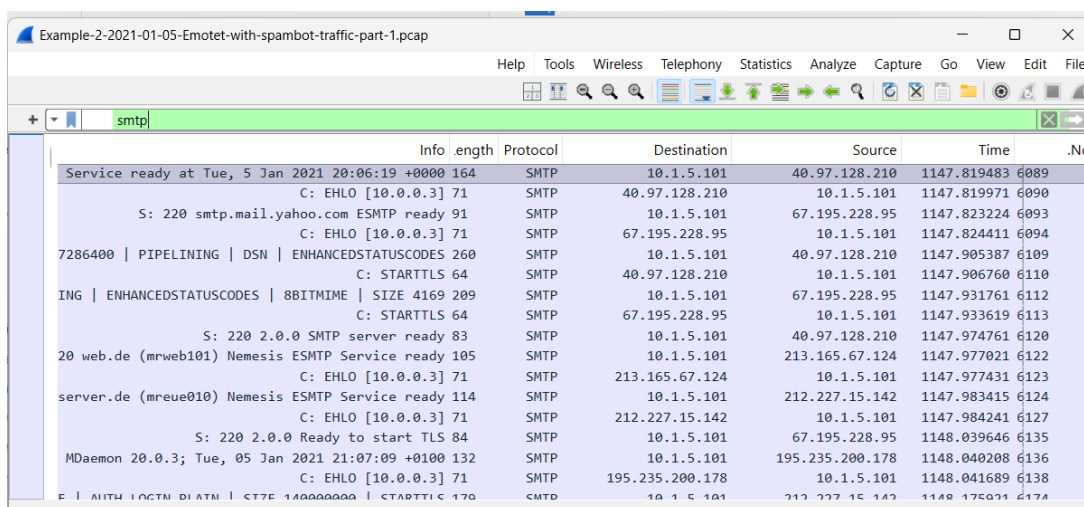
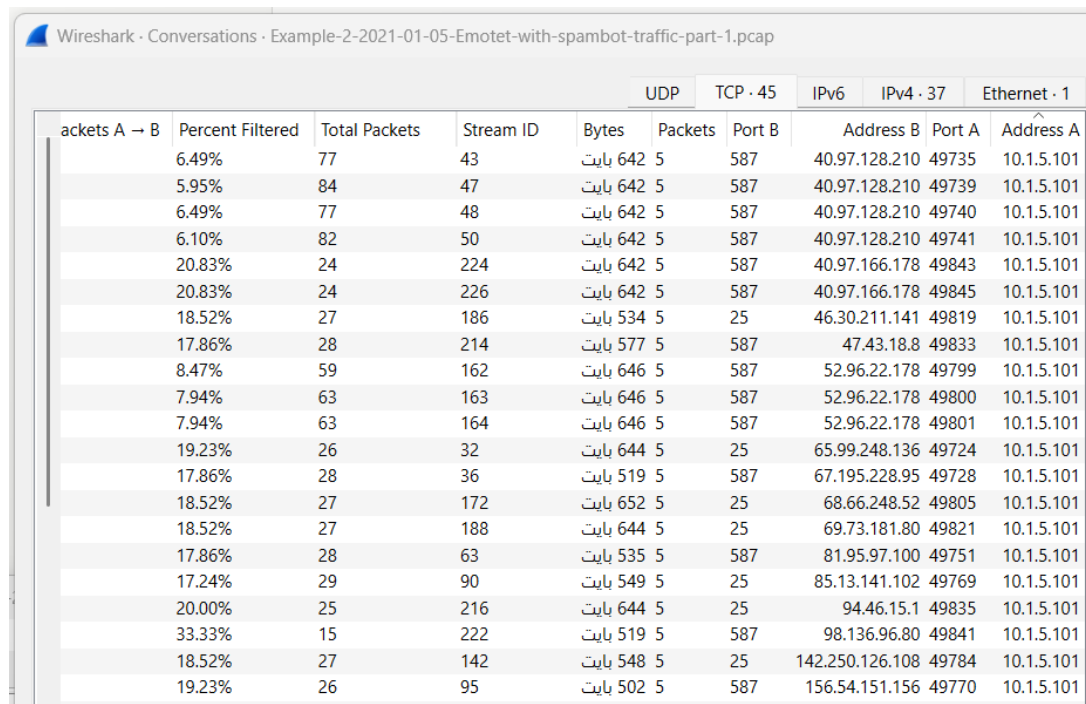


FIGURE 1.12 – filtre smtp

Activité SMTP : Le filtre `smtp` révèle que la machine infectée `10.1.5.101` contacte de nombreux serveurs de messagerie externes : `smtp.mail.yahoo.com`, des serveurs `web.de`, et `MDaemon`. Les commandes SMTP observées (`EHLO`, `STARTTLS`, `AUTH LOGIN`) confirment des tentatives d'authentification sur ces serveurs pour l'envoi de spam.



Wireshark · Conversations · Example-2-2021-01-05-Emotet-with-spambot-traffic-part-1.pcap									
UDP TCP · 45 IPv6 IPv4 · 37 Ethernet · 1									
packets A → B	Percent Filtered	Total Packets	Stream ID	Bytes	Packets	Port B	Address B	Port A	Address A
6.49%	77	43	43	بايت 642	5	587	40.97.128.210	49735	10.1.5.101
5.95%	84	47	47	بايت 642	5	587	40.97.128.210	49739	10.1.5.101
6.49%	77	48	48	بايت 642	5	587	40.97.128.210	49740	10.1.5.101
6.10%	82	50	50	بايت 642	5	587	40.97.128.210	49741	10.1.5.101
20.83%	24	224	224	بايت 642	5	587	40.97.166.178	49843	10.1.5.101
20.83%	24	226	226	بايت 642	5	587	40.97.166.178	49845	10.1.5.101
18.52%	27	186	186	بايت 534	5	25	46.30.211.141	49819	10.1.5.101
17.86%	28	214	214	بايت 577	5	587	47.43.18.8	49833	10.1.5.101
8.47%	59	162	162	بايت 646	5	587	52.96.22.178	49799	10.1.5.101
7.94%	63	163	163	بايت 646	5	587	52.96.22.178	49800	10.1.5.101
7.94%	63	164	164	بايت 646	5	587	52.96.22.178	49801	10.1.5.101
19.23%	26	32	32	بايت 644	5	25	65.99.248.136	49724	10.1.5.101
17.86%	28	36	36	بايت 519	5	587	67.195.228.95	49728	10.1.5.101
18.52%	27	172	172	بايت 652	5	25	68.66.248.52	49805	10.1.5.101
18.52%	27	188	188	بايت 644	5	25	69.73.181.80	49821	10.1.5.101
17.86%	28	63	63	بايت 535	5	587	81.95.97.100	49751	10.1.5.101
17.24%	29	90	90	بايت 549	5	25	85.13.141.102	49769	10.1.5.101
20.00%	25	216	216	بايت 644	5	25	94.46.15.1	49835	10.1.5.101
33.33%	15	222	222	بايت 519	5	587	98.136.96.80	49841	10.1.5.101
18.52%	27	142	142	بايت 548	5	25	142.250.126.108	49784	10.1.5.101
19.23%	26	95	95	بايت 502	5	587	156.54.151.156	49770	10.1.5.101

FIGURE 1.13 – Conversations

Conversations TCP : Les conversations montrent des connexions massives depuis `10.1.5.101` vers de nombreuses destinations distinctes sur les ports **587** (SMTP+TLS) et **25** (SMTP), signature caractéristique d'une campagne de spam automatisée.

Verdict : Trafic **malveillant**. Activité spambot Emotet confirmée par l'envoi massif d'emails via SMTP/587 vers de multiples serveurs de messagerie externes.

1.5 Example-5-2020-08-18-Emotet-with-Qakbot — Double infection

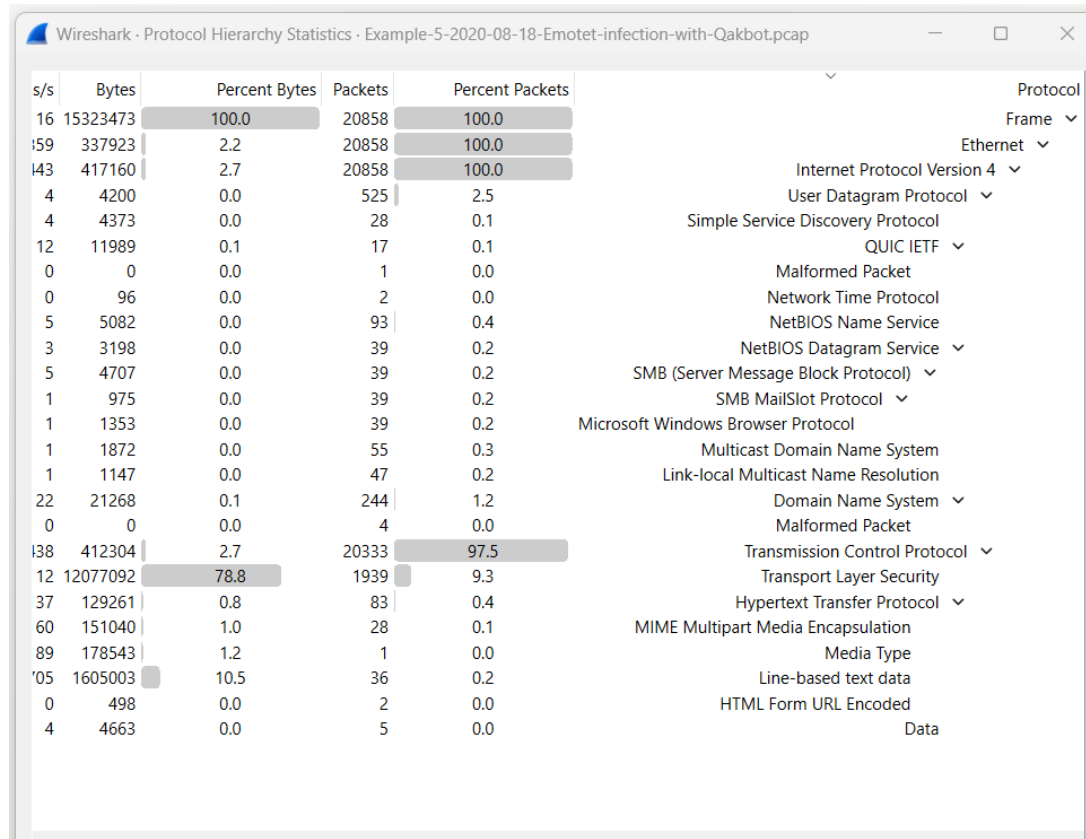


FIGURE 1.14 – Protocol Hierarchy

Protocoles dominants : L'analyse via *Protocol Hierarchy* révèle une dominance écrasante de TLS (78,8% des bytes – 1939 paquets), indiquant que la majorité des communications malveillantes sont chiffrées. HTTP reste présent de manière marginale (0,4% – 83 paquets) pour le beaconing initial. La présence de QUIC suggère également une activité réseau légitime en parallèle.

No.	Time	Source	Destination	Protocol	Length	Info
10	1.240601	192.168.100.101	198.70.69.144	HTTP	151	GET /ncsi.txt HTTP/1.1
11	11.379790	192.168.100.101	239.255.255.250	SSDP	215	M-SEARCH * HTTP/1.1
12	12.380463	192.168.100.101	239.255.255.250	SSDP	215	M-SEARCH * HTTP/1.1
13	13.000955	192.168.100.101	166.62.28.83	HTTP	548	GET /actor/security-area/s7iIICv-58i5sKfLjN/ HTTP/1.1
14	13.380058	192.168.100.101	239.255.255.250	SSDP	215	M-SEARCH * HTTP/1.1
15	14.383009	192.168.100.101	239.255.255.250	SSDP	215	M-SEARCH * HTTP/1.1
16	77.614083	192.168.100.101	82.163.245.38	HTTP	924	POST /hKjcutGS/zhypqGGjVaF0Vacj/sgQzDBwLzNMb/ HTTP/1.1
17	83.923742	192.168.100.101	82.163.245.38	HTTP	924	POST /MMLp9m0/5VlLqUm/hSjzQXaM6wzSc6/purwRGj/ HTTP/1.1
18	84.821748	192.168.100.101	45.55.82.2	HTTP	352	POST /YWXhUDN/Fp1aNXv8WD6/ HTTP/1.1
19	90.102365	192.168.100.101	82.163.245.38	HTTP	924	POST /ICy54/t577cjjb6rPz1eR/YNZFPMTjZFYaYey/ HTTP/1.1
20	90.739477	192.168.100.101	45.55.82.2	HTTP	588	POST /bFd2SwL/0VNa1nof1MAd/ HTTP/1.1
21	91.461912	192.168.100.101	82.163.245.38	HTTP	924	POST /W40YnrF77vnb03Itq/ HTTP/1.1
22	96.179746	192.168.100.101	82.163.245.38	HTTP	924	POST /ETue6Cn/y5azqqwYkf/VlpIG1zuo8svWGxm3a4/ HTTP/1.1
23	102.432994	192.168.100.101	82.163.245.38	HTTP	924	POST /IXhK/U9h4SFyPyUImTdYG/ntuSQxsh5Xkds1f/ HTTP/1.1
24	102.679322	192.168.100.101	45.55.82.2	HTTP	540	POST /YeY77m/k1WgEucj/JeCvml7q4zooQKZ/Vobj/ HTTP/1.1
25	105.457854	192.168.100.101	82.163.245.38	HTTP	924	POST /JbbP3e/SpkePr/Bzgh/3wb4jw5nixXVTmmhRS/ HTTP/1.1

FIGURE 1.15 – filtre HTTP request

Indicateurs C2 Emotet : Le filtre `http.request` révèle des requêtes HTTP avec des URIs pseudo-aléatoires longs caractéristiques d'Emotet, dirigées vers 82.163.245.38. Le filtre `http.request.method == "POST"` confirme un beaconing C2 actif vers ce serveur ainsi que vers 45.55.82.2.

No.	Time	Source	Destination	Protocol	Length	Info
33	1.720382	192.168.100.101	204.79.197.200	TLSv1.2	252	Client Hello (SNI=www.bing.com)
86	3.382501	192.168.100.101	52.242.211.89	TLSv1.2	238	Client Hello (SNI=client.wns.windows.com)
202	14.151857	192.168.100.101	13.107.42.23	TLSv1.2	571	Client Hello (SNI=config.edge.skype.com)
353	50.862359	192.168.100.101	204.79.197.200	TLSv1.2	252	Client Hello (SNI=www.bing.com)
386	54.303302	192.168.100.101	52.109.20.3	TLSv1.2	249	Client Hello (SNI=office15client.microsoft.com)
406	55.023039	192.168.100.101	52.109.8.23	TLSv1.2	246	Client Hello (SNI=nexus.officeapps.live.com)
424	55.738987	192.168.100.101	52.109.8.20	TLSv1.2	251	Client Hello (SNI=nexusrules.officeapps.live.com)
441	57.704673	192.168.100.101	23.76.192.84	TLSv1.2	237	Client Hello (SNI=gameplayapi.intel.com)
458	63.665285	192.168.100.101	43.255.154.32	TLSv1.2	232	Client Hello (SNI=samaritantec.com)
1934	171.639936	192.168.100.101	13.107.246.10	TLSv1.2	262	Client Hello (SNI=pti.store.microsoft.com)
1980	279.802687	192.168.100.101	52.114.128.69	TLSv1.2	268	Client Hello (SNI=v10.events.data.microsoft.com)
1998	280.329314	192.168.100.101	52.114.132.91	TLSv1.2	268	Client Hello (SNI=v20.events.data.microsoft.com)
2088	599.018620	192.168.100.101	13.107.246.10	TLSv1.2	246	Client Hello (SNI=maps.windows.com)
2098	599.120793	192.168.100.101	40.91.76.238	TLSv1.2	265	Client Hello (SNI=licensing.mp.microsoft.com)
2150	600.483245	192.168.100.101	52.183.220.149	TLSv1.2	252	Client Hello (SNI=settings-win.data.microsoft.com)
2178	601.280410	192.168.100.101	104.45.177.233	TLSv1.2	265	Client Hello (SNI=fe2cr.update.microsoft.com)

FIGURE 1.16 – Filtre handshake type

Indicateurs C2 Qakbot : Le filtre `tls.handshake.type == 1` révèle un SNI suspect : `samaritantec.com` (IP 43.255.154.32), qui se distingue des domaines Microsoft légitimes environnants. Ce domaine constitue un indicateur de compromission (IOC) lié à Qakbot. Le filtre `tcp.dstport == 447` ne retourne aucun résultat, indiquant que Qakbot utilise ici le port 443 standard pour masquer son trafic.

Verdict : Trafic **malveillant**. Double infection Emotet + Qakbot confirmée par la présence de deux canaux C2 distincts, un via HTTP avec URIs aléatoires (Emotet) et un via TLS avec SNI suspect (Qakbot).

1.6 2021-10-14-Stolen-Images-Evidence-BazarLoader — Téléchargement payload

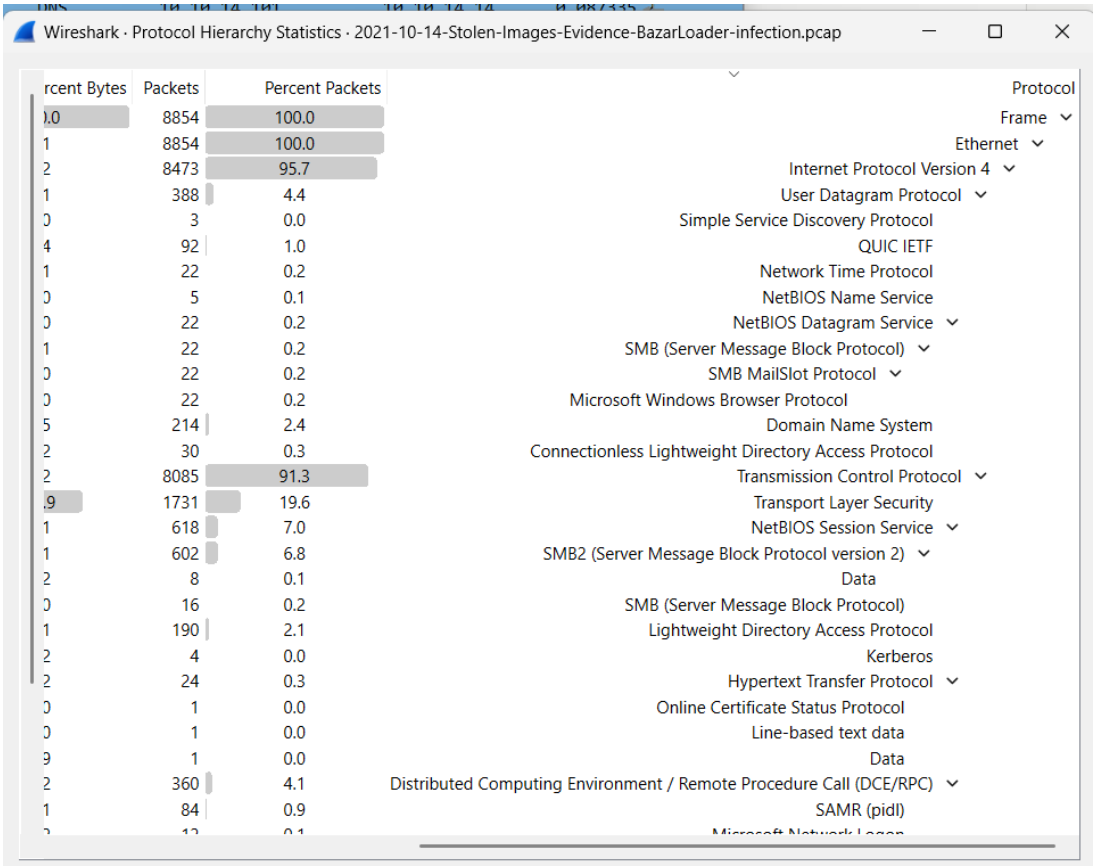


FIGURE 1.17 – Protocol Hierarchy

Protocoles dominants : L’analyse via *Protocol Hierarchy* révèle une combinaison de protocoles caractéristique d’une infection avancée : TLS (19,6%), SMB2 (6,8%), LDAP (2,1%), DCE/RPC (4,1%) et Kerberos. Cette combinaison indique non seulement un téléchargement de payload, mais aussi une phase de **reconnaissance et mouvement latéral** au sein du réseau interne.

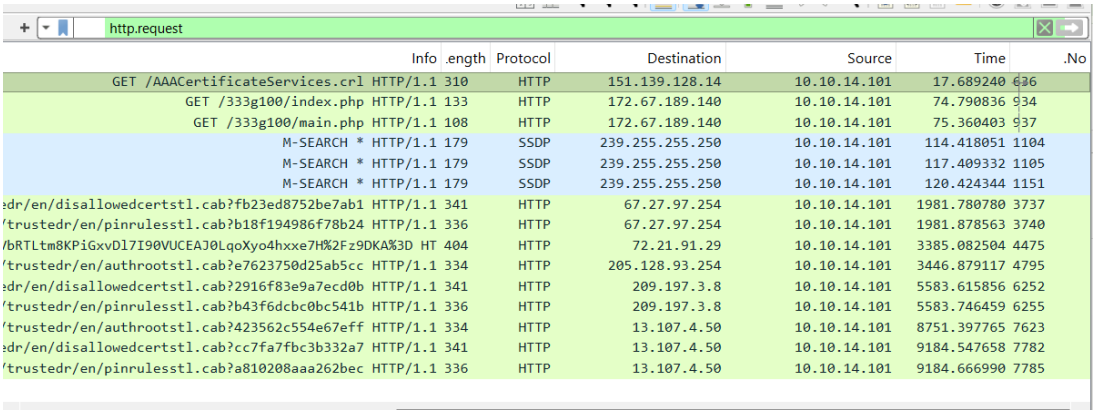
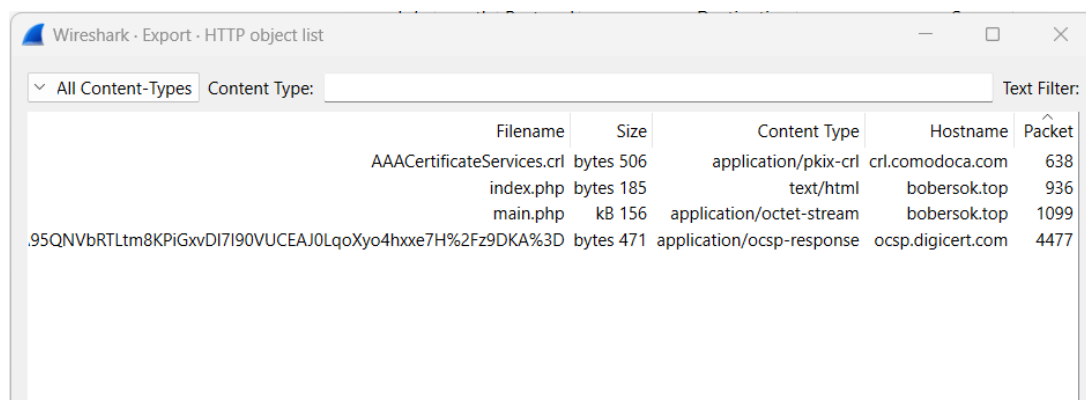


FIGURE 1.18 – HTTP request

Téléchargement du payload : Le filtre `http.request` révèle des requêtes GET vers le domaine C2 `bobersok.top` :

- GET `/333g100/index.php` – page de contrôle initiale
- GET `/333g100/main.php` – téléchargement du payload principal

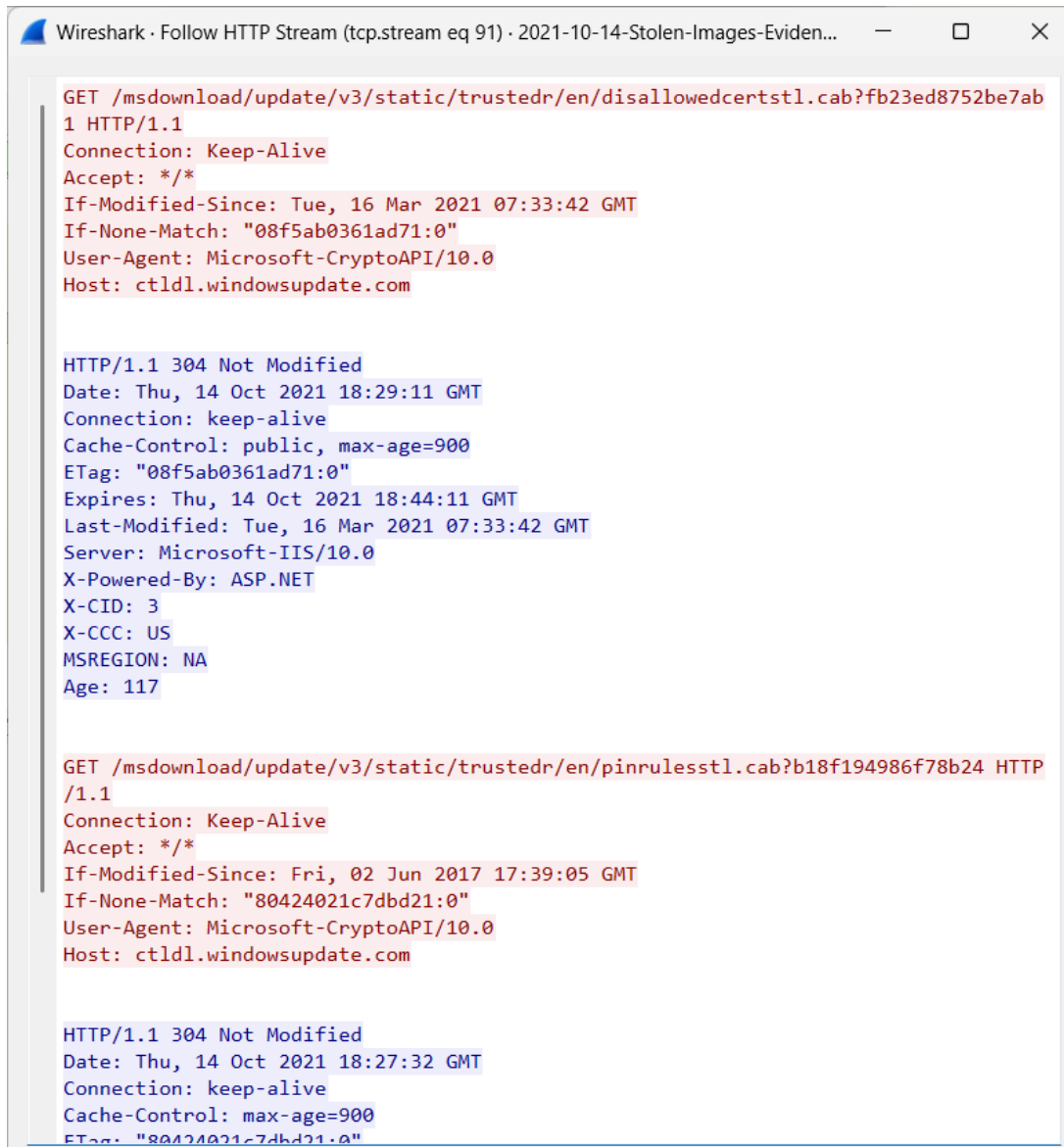


The image shows a screenshot of the 'Wireshark - Export - HTTP object list' window. It contains a table with the following data:

Filename	Size	Content Type	Hostname	Packet
AAACertificateServices.crl	bytes 506	application/pkix-crl	crl.comodoca.com	638
index.php	bytes 185	text/html	bobersok.top	936
main.php	kB 156	application/octet-stream	bobersok.top	1099
.95QNVbRTLm8KPiGxvDI7I90VUCEAJ0LqoXyo4hxxe7H%2Fz9DKA%3D	bytes 471	application/ocsp-response	ocsp.digicert.com	4477

FIGURE 1.19 – export des objets HTTP

L'export des objets HTTP (*File* → *Export Objects* → *HTTP*) confirme le téléchargement de `main.php` (156 Ko, `application/octet-stream`) depuis `bobersok.top` – signature d'un exécutable ou DLL malveillant déguisé en fichier PHP.



```

Wireshark · Follow HTTP Stream (tcp.stream eq 91) · 2021-10-14-Stolen-Images-Eviden...

GET /msdownload/update/v3/static/trustedr/en/disallowedcertstl.cab?fb23ed8752be7ab
1 HTTP/1.1
Connection: Keep-Alive
Accept: */*
If-Modified-Since: Tue, 16 Mar 2021 07:33:42 GMT
If-None-Match: "08f5ab0361ad71:0"
User-Agent: Microsoft-CryptoAPI/10.0
Host: ctldl.windowsupdate.com

HTTP/1.1 304 Not Modified
Date: Thu, 14 Oct 2021 18:29:11 GMT
Connection: keep-alive
Cache-Control: public, max-age=900
ETag: "08f5ab0361ad71:0"
Expires: Thu, 14 Oct 2021 18:44:11 GMT
Last-Modified: Tue, 16 Mar 2021 07:33:42 GMT
Server: Microsoft-IIS/10.0
X-Powered-By: ASP.NET
X-CID: 3
X-CCC: US
MSREGION: NA
Age: 117

GET /msdownload/update/v3/static/trustedr/en/pinrulesstl.cab?b18f194986f78b24 HTTP
/1.1
Connection: Keep-Alive
Accept: */*
If-Modified-Since: Fri, 02 Jun 2017 17:39:05 GMT
If-None-Match: "80424021c7dbd21:0"
User-Agent: Microsoft-CryptoAPI/10.0
Host: ctldl.windowsupdate.com

HTTP/1.1 304 Not Modified
Date: Thu, 14 Oct 2021 18:27:32 GMT
Connection: keep-alive
Cache-Control: max-age=900
ETag: "80424021c7dbd21:0"

```

FIGURE 1.20 – Follow http stream

Mouvement latéral : La présence de SMB2, LDAP, DCE/RPC et Kerberos indique que le malware a initié une phase de reconnaissance Active Directory et de mouvement latéral après l'infection initiale, comportement typique des précurseurs de ransomware.

Camouflage : Le trafic malveillant est mélangé avec des requêtes légitimes vers ctldl.windowsupdate.com (Windows Update) pour masquer l'activité malveillante.

Verdict : Trafic **malveillant**. Infection BazarLoader confirmée par téléchargement de payload depuis bobersok.top, suivi d'une phase de reconnaissance réseau via SMB2/LDAP/DCE-RPC.

1.7 2021-10-20-TA551-pushes-Sliver — C2 Sliver

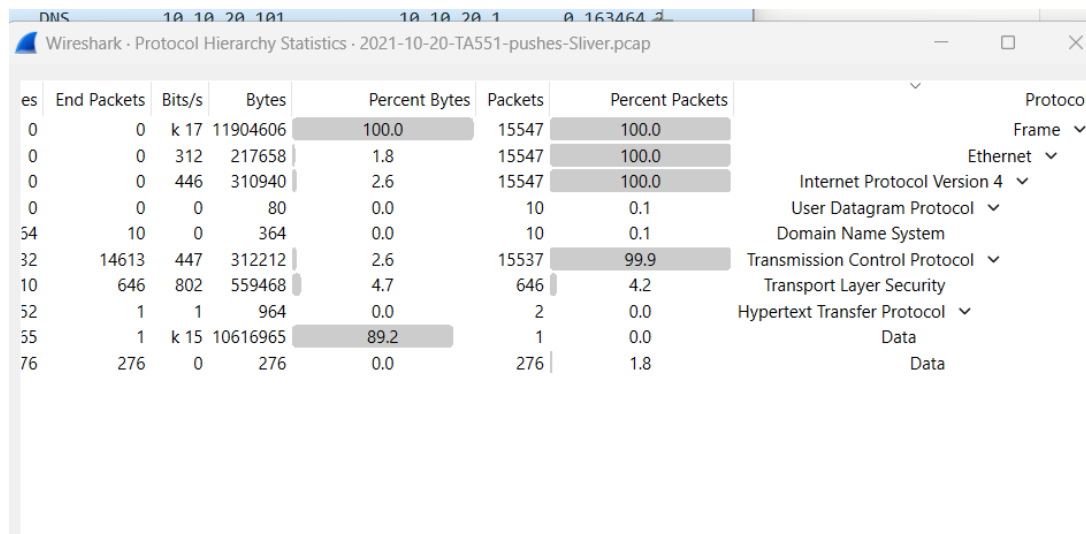


FIGURE 1.21 – Protocol Hierarchy

Protocoles dominants : L'analyse via *Protocol Hierarchy* révèle une capture dominée à 99,9% par TCP, avec une proportion exceptionnellement élevée de données brutes (89,2% des bytes). TLS représente 4,2% des paquets, et HTTP est quasi absent (2 paquets). Cette distribution est caractéristique d'un trafic C2 cherchant à minimiser son empreinte protocolaire.

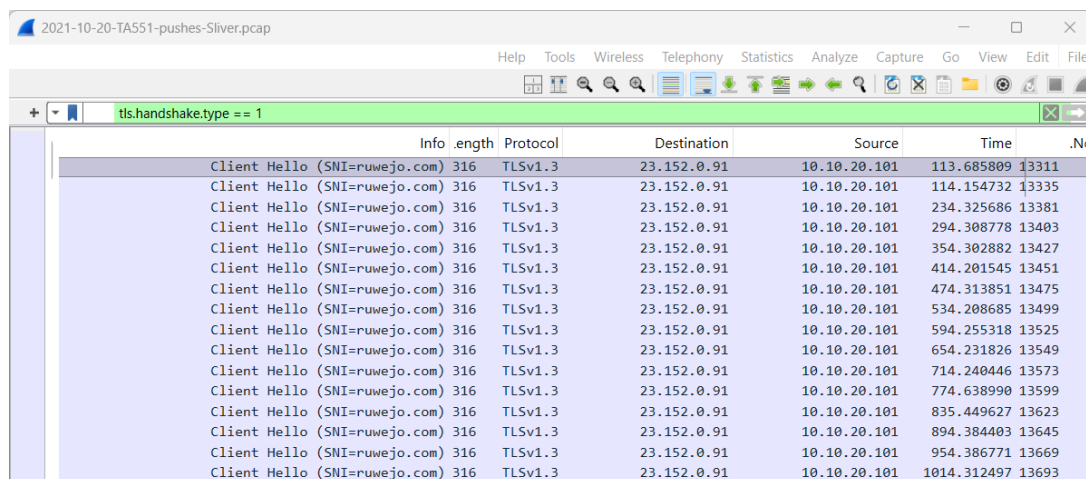


FIGURE 1.22 – handshake

Beaconing C2 Sliver : Le filtre `tls.handshake.type == 1` révèle un beaconing extrêmement régulier vers le domaine `rumejo.com` (IP `23.152.0.91`) via TLSv1.3, avec des intervalles d'exactement 60 secondes entre chaque Client Hello. Cette régularité mathématique est la signature d'un **beacon automatisé** du framework Sliver.

No.	Time	Source	Destination	Protocol	Length	Info
1	0.333346	185.53.46.50	10.10.20.101	TCP	58	Win=64240 Len=0 MSS=1460 [SYN, ACK] 53204 → 80
7	0.333697	185.53.46.50	10.10.20.101	TCP	54	Seq=1 Ack=553 Win=64240 Len=0 [ACK] 53204 → 80
8	0.627254	185.53.46.50	10.10.20.101	TCP	1442	PDU reassembled in 13303] [PSH, ACK] 53204 → 80
10	0.657140	185.53.46.50	10.10.20.101	TCP	1442	PDU reassembled in 13303] [PSH, ACK] 53204 → 80
11	0.657163	185.53.46.50	10.10.20.101	TCP	1442	PDU reassembled in 13303] [PSH, ACK] 53204 → 80
12	0.657229	185.53.46.50	10.10.20.101	TCP	1442	PDU reassembled in 13303] [PSH, ACK] 53204 → 80
14	0.657250	185.53.46.50	10.10.20.101	TCP	1442	PDU reassembled in 13303] [PSH, ACK] 53204 → 80
16	0.657450	185.53.46.50	10.10.20.101	TCP	1514	[TCP PDU reassembled in 13303] [ACK] 53204 → 80
17	0.657456	185.53.46.50	10.10.20.101	TCP	1514	[TCP PDU reassembled in 13303] [ACK] 53204 → 80
18	0.657462	185.53.46.50	10.10.20.101	TCP	1298	PDU reassembled in 13303] [PSH, ACK] 53204 → 80
19	0.657476	185.53.46.50	10.10.20.101	TCP	1442	PDU reassembled in 13303] [PSH, ACK] 53204 → 80
20	0.657511	185.53.46.50	10.10.20.101	TCP	1442	PDU reassembled in 13303] [PSH, ACK] 53204 → 80
23	0.817210	185.53.46.50	10.10.20.101	TCP	1442	PDU reassembled in 13303] [PSH, ACK] 53204 → 80
25	0.827101	185.53.46.50	10.10.20.101	TCP	1514	[TCP PDU reassembled in 13303] [ACK] 53204 → 80
26	0.827113	185.53.46.50	10.10.20.101	TCP	1370	PDU reassembled in 13303] [PSH, ACK] 53204 → 80
28	0.827389	185.53.46.50	10.10.20.101	TCP	1442	PDU reassembled in 13303] [PSH, ACK] 53204 → 80

FIGURE 1.23 – filtre tcp.dstport != 80 && tcp.dstport != 443

Ports non standards : Le filtre `tcp.dstport != 80 && tcp.dstport != 443` révèle des connexions massives depuis 185.53.46.50 vers la machine infectée sur le port 80, mais transportant des données TCP brutes (non HTTP). L'utilisation du port 80 pour du trafic non-HTTP est une technique de camouflage classique des frameworks C2.

Wireshark · Endpoints · 2021-10-20-TA551-pushes-Sliver.pcap										
						UDP	TCP · 94	IPv6	IPv4 · 3	Ethernet · 2
City	Country	Rx Bytes	Rx Packets	Tx Bytes	Tx Packets	Percent Filtered	Total Packets	Bytes	Packets	Address
		11 م.ب	8,750	0 بايت	0	56.28%	15,547	11 م.ب	8,750	10.10.20.101
		0 بايت	0	447 كيلوبايت	1,115	49.91%	2,234	447 كيلوبايت	1,115	23.152.0.91
		0 بايت	0	11 م.ب	7,635	57.39%	13,303	11 م.ب	7,635	185.53.46.50

FIGURE 1.24 – Endpoints

Endpoints : Seulement 3 IPs impliquées : la machine infectée 10.10.20.101, le serveur C2 principal 23.152.0.91 (ruwejo.com) et un second serveur 185.53.46.50 responsable du transfert massif de données (11 Mo reçus).

Verdict : Trafic **malveillant**. Infection Sliver C2 confirmée par beaconing TLS régulier vers **ruwejo.com**, transfert massif de données brutes, et utilisation du port 80 pour masquer les communications C2.

1.8 Conclusion générale

Ce laboratoire a permis de mettre en pratique une méthodologie complète d'analyse forensique réseau sur des captures réelles issues de compromissions documentées. À travers l'analyse comparative de huit fichiers pcap, plusieurs enseignements majeurs ont été dégagés.

Trafic normal vs trafic malveillant : La capture `lotsofweb` établit une référence claire : trafic HTTP/DNS vers des domaines légitimes, port 80 exclusivement, absence de TLS suspect et d'URIs aléatoires. En contraste, les captures malveillantes présentent systématiquement des POSTs HTTP avec URIs pseudo-aléatoires, des connexions TLS vers des domaines inconnus, et des protocoles internes (SMB2, LDAP, DCE/RPC) indiquant des mouvements latéraux.

Indicateurs récurrents dans les captures malveillantes :

- Requêtes HTTP POST avec URIs pseudo-aléatoires longs (Emotet, Qakbot)
- Beaconing TLS régulier vers des domaines suspects (Sliver)
- Activité SMTP massive vers des serveurs externes (spambot Emotet)
- Utilisation de SMB2, LDAP, Kerberos et DCE/RPC (BazarLoader, Trickbot)
- Connexions sur ports non standards : 447 (Trickbot), 587 (spam)
- Téléchargements `application/octet-stream` depuis des domaines suspects (BazarLoader)

Scénarios les plus identifiables visuellement : L'activité spambot Emotet (Exemples 2 et 3) est la plus immédiatement visible grâce au volume SMTP massif. Le beaconing Sliver se distingue par sa régularité mathématique (intervalles de 60 secondes). Les infections Trickbot sont identifiables par le port 447 caractéristique.

Filtres et statistiques les plus utiles :

- `http.request.method == "POST"` : détection rapide du beaconing C2
- `tls.handshake.type == 1` : identification des SNI suspects
- `smtp` : détection immédiate de l'activité spambot
- `tcp.dstport == 447` : signature Trickbot
- *Statistics* → *Protocol Hierarchy* : vue d'ensemble instantanée de la nature du trafic
- *File* → *Export Objects* → *HTTP* : extraction des payloads téléchargés

Pertinence de Wireshark en forensique réseau : Wireshark s'est révélé un outil indispensable pour cette investigation. Sa capacité à combiner analyse protocolaire, filtrage précis, suivi de flux et export d'artefacts permet de reconstituer fidèlement la kill chain d'une infection, depuis le téléchargement initial du payload jusqu'aux communications C2 et aux mouvements latéraux. Utilisé en complément d'outils de forensique mémoire comme Volatility, il constitue un pilier de toute investigation numérique complète.

